
FastPartz

Security & SD-WAN Proposal

Date: February 2026

Scope: 4 branches (UAE) + offsite backup

Type: Technical proposal & recommendation

Table of Contents

1. Executive Summary	3
2. Solution Overview	4
3. Recommended Software	5
4. Hardware & Cost	6
Cost Summary	6
5. Network Architecture	7
6. Traffic Flow Architecture	8
7. Network Segmentation	9
Why Segment the Network?	9
IP Addressing Scheme	9
VLAN Roles	9
8. Security Layers	10
9. Encrypted Connectivity	11
Full-Mesh Topology	11
10. Backup Strategy (3-2-1)	12
11. Secure Remote Access	13
12. Ransomware Risk Assessment	14
13. Implementation & Emergency Reference	15
Proposed Timeline	15
Emergency Quick-Reference	15

1. Executive Summary

FastPartz operates four branches across the UAE, each running Windows Servers with vendor-supplied accounting software backed by MS SQL Server. Today, these servers sit directly on public IP addresses with RDP and SQL ports exposed to the internet, no firewalls, no antivirus, no backups, and no network segmentation. This configuration represents a critical security risk — exposed RDP is the #1 entry point for ransomware groups, and the absence of backups means any incident could result in total data loss.

The proposed solution would address every layer of this exposure through a unified, open-source security architecture. By placing an OPNsense firewall appliance at each branch, encrypting all inter-branch traffic through IPsec tunnels, segmenting networks with VLANs, hardening every server endpoint, and implementing a 3-2-1 backup strategy with immutable copies, the result would be a resilient posture built on commodity hardware with no recurring license costs for infrastructure.

Key outcomes of the proposed approach:

- **Zero public-facing ports** — full perimeter closure
- **4-VLAN segmentation** at every branch
- **VPN with MFA** replaces exposed RDP
- **AES-256 encryption** on all inter-branch links
- **3-2-1 backups** with immutable offsite copies
- **Real-time monitoring** with instant alerts

2. Solution Overview

The following table summarizes the proposed changes across seven security layers. Each layer addresses a specific gap in the current environment.

Layer	Current State	Proposed State
Perimeter	No firewall — public ports open to internet	OPNsense firewall at each branch; zero inbound ports
Transport	Unencrypted SQL sync over public internet	AES-256 IPsec tunnels, certificate-authenticated
Segmentation	Flat network — everything reachable	VLANs: servers, workstations, mgmt, guests isolated
Endpoint	No AV — Defender disabled	Windows Defender + enterprise AV with ransomware rules
Backup	No backups at all	3 copies, 2 media types, 1 offsite, immutable
Access	Direct RDP over internet	IKEv2 VPN with certificate + password + TOTP
Monitoring	No visibility into threats	IDS/IPS, DNS filtering, email + Telegram alerts

3. Recommended Software

All core software is open-source or free-tier — no recurring license costs for infrastructure. We recommend **ESET PROTECT** (~\$40/server/year) as the enterprise antivirus layer for central management and ransomware-specific shielding, bringing the total AV cost to approximately \$160/year for all four servers.

Software	Purpose	Key Features
OPNsense	Firewall / VPN / IDS	Stateful firewall, IPsec/IKEv2, Suricata IDS/IPS, Unbound DNS with blocklists, DHCP, DynDNS, web GUI
Suricata	Intrusion Detection	ET Open + Abuse.ch rulesets (~35k rules), inline blocking, protocol anomaly detection
Unbound DNS	DNS Security	DNSBL blocklists (malware/phishing), DNSSEC validation, DNS-over-TLS upstream
Windows Defender	Endpoint AV	Real-time protection, Tamper Protection, ASR rules, cloud-delivered protection
ESET PROTECT	Enterprise AV	Central cloud console, ransomware shield, behavioral detection
Veeam Backup CE	Server Backup	Full/incremental, MS SQL VSS, application-aware, AES-256 encryption (free for ≤10 workloads)
Restic	Cloud Backup	Backblaze B2 / Cloudflare R2 / S3 integration, encryption, deduplication, retention
NXLog CE	Log Forwarding	Forwards Windows Security events to central syslog for audit trail
Uptime Kuma	Monitoring	Ping/TCP/HTTP checks, web dashboard, push notifications, Docker-based

4. Hardware & Cost

Each branch would require two primary devices:

- **SD-WAN Edge (N100 Mini-PC)** — Intel N100, 2× 2.5GbE NICs, 8 GB DDR5, 128 GB NVMe, fanless, AES-NI hardware acceleration. Runs OPNsense as a dedicated firewall/VPN appliance. All branch traffic flows through this device. (\$150–200)
- **Managed Switch** — TP-Link TL-SG2428P or similar with 24× GbE, PoE+, 802.1Q VLAN support, web GUI. Provides network segmentation. For smaller branches, an 8-port model (TL-SG2210P) would be sufficient. (\$200–300)

Optional additions include a backup NAS at the master branch (Synology DS223, \$400–500) and an offsite NAS for geographic disaster recovery (\$400–500).

Cost Summary

Scenario	4 Branches	Grand Total
Core — N100 + managed switch per branch	\$1,520–2,200	\$1,520–2,200
Core + HA — add standby N100 per branch	\$2,120–3,000	\$2,120–3,000
Core + Backup NAS — master branch only	\$1,520–2,200 + \$400–500	\$1,920–2,700
Full — Core + HA + NAS + offsite NAS	\$2,120–3,000 + \$800–1,000	\$2,920–4,000

Total investment range: \$1,520 (minimum viable) to \$4,000 (full redundancy + offsite). All built on open-source software with no recurring infrastructure licensing.

5. Network Architecture

Each branch would follow the same topology: the existing broadband router hands off to a dedicated OPNsense appliance, which serves as the single gateway for all traffic. A managed switch downstream provides VLAN-based network segmentation.

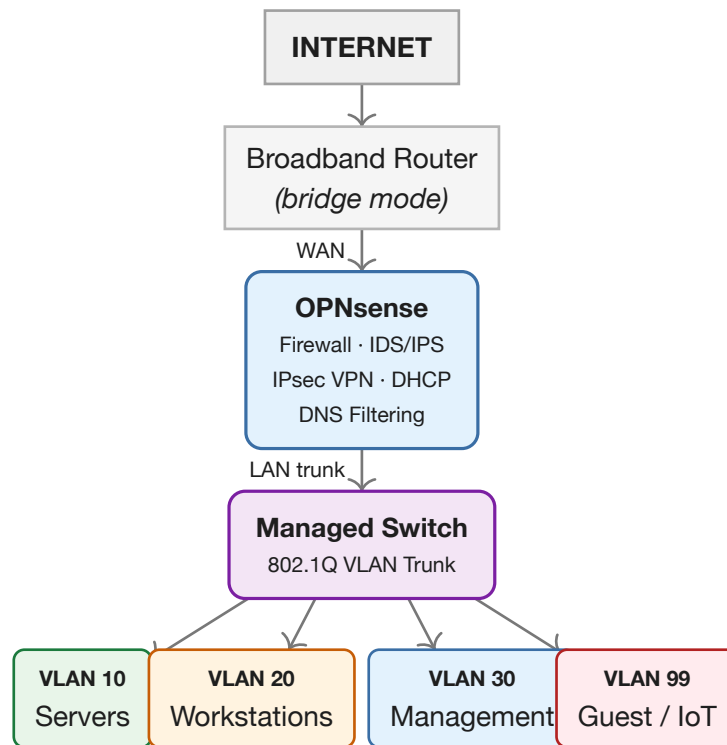


Figure 1: Proposed per-branch network topology

6. Traffic Flow Architecture

OPNsense would serve as the default gateway for every device. All traffic — internet-bound, inter-branch, and inter-VLAN — would pass through OPNsense for inspection and policy enforcement.

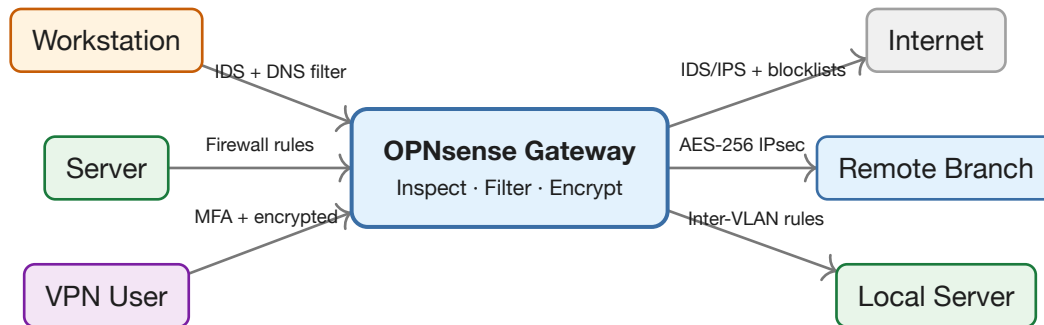


Figure 2: All traffic flows through OPNsense for inspection and policy enforcement

Traffic Type	Path	Protection
Server → Server (inter-branch)	OPNsense → IPsec tunnel → remote OPNsense	AES-256 encryption + IDS/IPS
Workstation → Internet	OPNsense → ISP	IDS/IPS + DNS blocklists
Workstation → Server (same branch)	OPNsense inter-VLAN routing	Firewall rules per port
Remote user → Server	IKEv2 VPN → OPNsense → Server	Encrypted + MFA authenticated

7. Network Segmentation

Why Segment the Network?

In a flat network, a single compromised device — whether a workstation hit by phishing or an IoT device with a default password — can reach every other device on the network. This is how ransomware spreads: once inside, it moves laterally to find servers, databases, and backups. Network segmentation through VLANs creates isolated zones with strict firewall rules between them. Even if an attacker compromises a workstation, they would be unable to reach servers in a different VLAN without passing through the OPNsense firewall, which enforces explicit per-port access rules. This approach dramatically limits the blast radius of any incident.

IP Addressing Scheme

Pattern: 10.<branch>.<vlan>.0/24

Branch	VLAN 10 (Servers)	VLAN 20 (Workstations)	VLAN 30 (Mgmt)	VLAN 99 (Guest)
Branch 1	10.1.10.0/24	10.1.20.0/24	10.1.30.0/24	10.1.99.0/24
Branch 2	10.2.10.0/24	10.2.20.0/24	10.2.30.0/24	10.2.99.0/24
Branch 3	10.3.10.0/24	10.3.20.0/24	10.3.30.0/24	10.3.99.0/24
Branch 4	10.4.10.0/24	10.4.20.0/24	10.4.30.0/24	10.4.99.0/24

VLAN Roles

VLAN	Name	Devices	Access Rules
10	Servers	Windows Servers, NAS, SQL	Reachable from workstations on SQL + file share ports only. Inter-branch via IPsec.
20	Workstations	User PCs, laptops	Can reach servers for SQL and file shares. Full inspected internet access.
30	Management	OPNsense GUI, switch mgmt	IT administrators only. All other VLANs blocked.
99	Guest / IoT	WiFi guests, printers, cameras	Fully isolated. Internet-only (HTTP/HTTPS). Cannot reach internal VLANs.

8. Security Layers

The proposed architecture combines network-level and endpoint-level defenses into a unified security model. Each layer would be deployed at every branch.

Defense Layer	What It Does	Priority
Stateful Firewall	Default-deny inbound on OPNsense. Closes all public ports — RDP, SQL, everything.	Critical
IDS/IPS (Suricata)	~35,000 signatures detect and block exploits, malware downloads, C2 callbacks.	Critical
DNS Filtering	Blocks connections to known malicious/phishing domains before they resolve.	High
VLAN Segmentation	Isolates servers, workstations, management, and guests behind firewall rules.	Critical
Encrypted Transport	IKEv2 IPsec with AES-256-GCM and certificate auth. Perfect Forward Secrecy.	Critical
Endpoint AV	Windows Defender + ASR rules + ESET PROTECT enterprise antivirus.	High
Server Hardening	Disable SMBv1, NetBIOS, LLMNR, PowerShell v2. Enable Windows Firewall, audit logging, account lockout.	High
Application Control	AppLocker/WDAC blocks executables from user profile, temp, and AppData folders.	Medium
Backup Immutability	3-2-1 backup with immutable snapshots. Ransomware cannot encrypt backup copies.	Critical
Monitoring & Alerts	IDS alerts, backup status, availability checks via email + Telegram notifications.	High

9. Encrypted Connectivity

The accounting software currently syncs SQL data between branches over the open internet. The proposed solution would route all inter-branch traffic through encrypted IPsec tunnels. Dynamic DNS (via Dynu, free) handles UAE's dynamic broadband IPs — if an IP changes, tunnels would auto-recover within 30–90 seconds.

Feature	Specification
Protocol	IKEv2 — supports dynamic IPs, NAT traversal, mobile clients
Authentication	X.509 certificates from a private CA (no shared passwords)
Encryption	AES-256-GCM (hardware-accelerated on N100 via AES-NI)
Key Exchange	ECDH Group 20 (384-bit NIST P-384)
Forward Secrecy	New keys every hour — past sessions cannot be decrypted
Failover	Dead Peer Detection recovers failed tunnels in ~60 seconds
NAT Traversal	Automatic via UDP 4500 — works behind any ISP router

Full-Mesh Topology

All four branches would be connected to each other via six encrypted IPsec tunnels, providing direct branch-to-branch communication. If any single tunnel fails, all other branches remain connected.

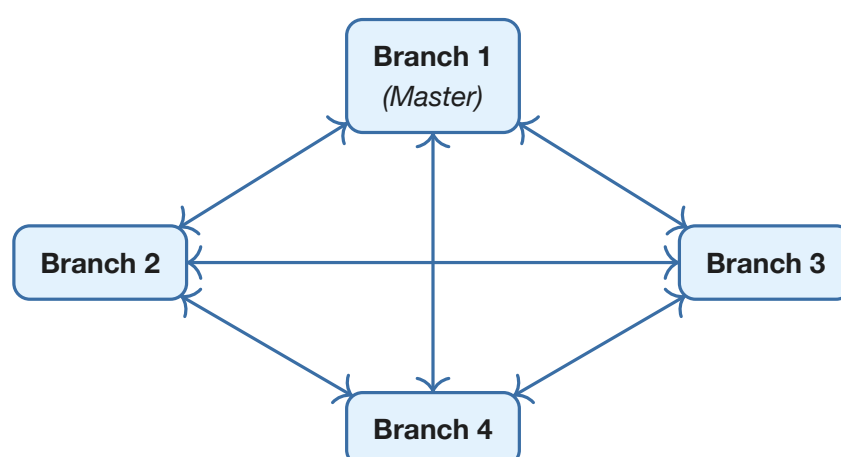


Figure 3: Full-mesh IPsec topology — 6 encrypted tunnels between all branch pairs

10. Backup Strategy (3-2-1)

The proposed approach follows the industry-standard 3-2-1 rule: three copies of data, on two different media types, with one copy offsite. We recommend Backblaze B2 for the cloud offsite tier — it offers the best balance of cost (\$5/TB/month), immutability (Object Lock), and ease of use.

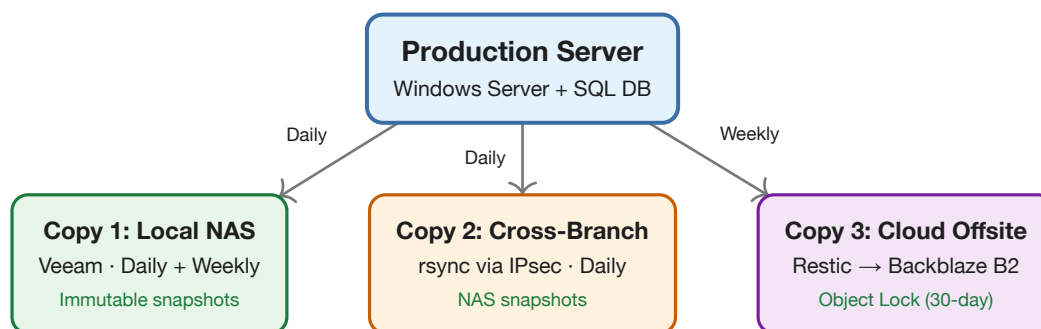


Figure 4: Proposed 3-2-1 backup architecture with immutability at every tier

Copy	Location	Method	Schedule	Immutability
1 — Local	Synology NAS (master branch)	Veeam CE (SQL-aware, free)	Daily incremental + weekly full	NAS snapshots (7-day retention)
2 — Cross-branch	Partner branch NAS via IPsec	rsync/roclone with encryption	Daily sync	NAS snapshots
3 — Cloud	Backblaze B2	Restic with AES-256	Weekly full + daily incremental	Object Lock (30-day, cannot be deleted)

11. Secure Remote Access

Remote users would connect to the branch OPNsense via IKEv2 VPN. No client software would be needed — Windows, macOS, iOS, and Android all include built-in IKEv2 support. This approach would completely replace direct RDP access from the internet.

Feature	Detail
Protocol	IKEv2 (native on all modern operating systems)
Authentication	Certificate + Username/Password + TOTP (multi-factor)
Encryption	AES-256-GCM
Split Tunneling	Only branch traffic goes through VPN; internet browsing stays local
VPN Subnet	10.10.10.0/24 (dedicated, isolated from all branch VLANs)
DNS	OPNsense Unbound — malware/phishing domains blocked for VPN users too

VPN Users Can Access

- Servers: RDP, SQL, file shares
- Only on authorized ports
- Filtered through OPNsense rules

VPN Users Cannot Access

- Workstation VLAN
- Management VLAN
- Guest / IoT VLAN
- Other VPN users

Vendor and support access would be handled through time-limited VPN accounts restricted to specific server IPs and ports, with full session logging and immediate revocation after each support session.

12. Ransomware Risk Assessment

This matrix maps every significant attack vector against the current exposure and the proposed mitigation. Four of the fourteen vectors are currently at **critical** risk level.

#	Attack Vector	Current	Proposed Mitigation	After
1	RDP Brute Force	CRITICAL	OPNsense blocks all inbound. RDP only via VPN.	ELIMINATED
2	SQL Exploitation	CRITICAL	OPNsense blocks inbound. SQL bound to VLAN 10.	ELIMINATED
3	Phishing / Email	HIGH	SPF/DKIM/DMARC + user training + attachment blocking.	MEDIUM
4	Malicious Downloads	HIGH	IDS/IPS + DNS blocklists + Defender + ESET + AppLocker.	LOW
5	USB / Removable	MEDIUM	Disable AutoRun. ASR blocks untrusted USB processes.	LOW
6	Lateral Movement	CRITICAL	VLAN segmentation + firewalls + separate admin accounts.	LOW
7	Credential Theft	HIGH	MFA on VPN. Account lockout. LSASS protection.	LOW
8	Supply Chain	MEDIUM	Auto-patching. AppLocker whitelist. Vendor access time-limited.	LOW
9	Insider Threat	MEDIUM	Least privilege. Audit logging. No shared accounts.	LOW
10	WiFi	MEDIUM	WPA3. Guest SSID on isolated VLAN 99.	LOW
11	Printers / IoT	LOW	VLAN 99 isolated. Only print ports from workstations.	LOW
12	DNS Attacks	MEDIUM	DNSSEC + DNS-over-TLS + blocklists on OPNsense.	LOW
13	Backup Destruction	CRITICAL	3-2-1 backup + immutable snapshots + Object Lock.	LOW
14	Unpatched Vulns	HIGH	Automated Windows Update. Monthly patch review.	LOW

13. Implementation & Emergency Reference

Proposed Timeline

The deployment would be structured in six weekly phases, with the master branch serving as the pilot before rolling out to remaining locations.

Week	Scope	Deliverable
1	Hardware procurement + OPNsense installation	4 configured OPNsense appliances
2	Branch 1 pilot — VLANs, firewall, IDS/IPS, DNS	Master branch fully segmented and protected
3	Deploy branches 2–4 + 6 IPsec tunnels	All branches connected. SQL sync encrypted.
4	Server hardening + AV + backup setup	All servers hardened. Daily backups running.
5	VPN with MFA + monitoring + offsite backup	Remote access live. 3-2-1 backup complete.
6	Testing, verification, documentation, training	All tests passed. Runbooks delivered.

Estimated total deployment: 6 weeks. Each phase is designed to be independently valuable — the network would become progressively more secure from week one.

Emergency Quick-Reference

Suspected ransomware: ① Isolate — pull Ethernet immediately ② Do not reboot (preserves forensic evidence) ③ Check other branches and backup integrity ④ Restore from most recent clean backup ⑤ Investigate entry point via Suricata + Windows logs ⑥ Harden the exploited vulnerability

OPNsense failure: Branch loses connectivity. Bypass by pointing workstations to broadband router (internet-only, no security). Boot standby N100 (~5 min) or reinstall from XML config backup (~30 min).

IPsec tunnel down: Wait 2 minutes for DPD auto-recovery. If still down, check remote branch broadband. Try disconnect/reconnect from OPNsense GUI. Verify DynDNS has updated if IP changed.